

Continuação da Análise STPA — Controlador InfoPrivSec

Step 4 (Cenários de Perda) e Requisitos Derivados — Estudo de Caso SisAPEC / SUS sob a LGPD

7. STPA Step 4 — Cenários de Perda (Loss Scenarios)

Esta seção apresenta a continuação da análise STPA para o controlador InfoPrivSec e a ação de controle Review Code, contemplando a Etapa 4 (Identificação de Cenários de Perda), conforme solicitado na Task 7 do enunciado do projeto semestral.

Para cada uma das doze Ações de Controle Inseguras (UCA-IP-1 a UCA-IP-12) identificadas na Etapa 3, é apresentado pelo menos um cenário de perda, estruturado segundo os oito campos exigidos: UCA relacionada, controladores envolvidos, arquétipo do cenário, cenário de alto nível, solução de alto nível, cenário refinado, fatores causais e solução refinada.

Observação metodológica: em conformidade com a exigência explícita da Task 7, todos os cenários a seguir foram construídos sem incluir falha de componente como fator causal. Em cada narrativa, todos os controladores e componentes envolvidos atuam exatamente conforme suas especificações; a condição perigosa emerge da interação entre processos legítimos, modelos de processo incompletos, feedback inadequado ou objetivos conflitantes — e não de um mau funcionamento técnico ou humano isolado.

Cenário de Perda 1 — Relacionado à UCA-IP-1

UCA Relacionada	UCA-IP-1: A InfoPrivSec NÃO FORNECE a ação de controle Review Code quando a Pull Request modifica lógica de autenticação, autorização ou controle de acesso, e a alteração é integrada à branch principal sem revisão. [H-1, H-2]
Controladores Envolvidos	• InfoPrivSec • PR Management • Developer
Arquétipo do Cenário	Classe 2 — Feedback Inadequado / Falta de Informação para o Controlador
Cenário de Alto Nível	O feedback recebido pelo InfoPrivSec a partir do PR Management era tecnicamente correto, mas não continha informação suficiente para que a InfoPrivSec identificasse a necessidade de revisão obrigatória, resultando na ausência da ação de controle Review Code.

UCA Relacionada	UCA-IP-1: A InfoPrivSec NÃO FORNECE a ação de controle Review Code quando a Pull Request modifica lógica de autenticação, autorização ou controle de acesso, e a alteração é integrada à branch principal sem revisão. [H-1, H-2]
Solução de Alto Nível	O PR Management deve sinalizar explicitamente, como parte do feedback rotineiro enviado à InfoPrivSec, sempre que uma submissão alterar arquivos ou módulos associados a autenticação, autorização ou controle de acesso.
Cenário Refinado	Um desenvolvedor abre uma Pull Request que modifica o middleware de autorização de API responsável por validar o escopo de permissões de acesso a prontuários eletrônicos. O PR Management opera exatamente conforme especificado: gera corretamente o status da PR, calcula a cobertura de testes e disponibiliza esses dados à InfoPrivSec através do canal de feedback padrão (PR Status). Entretanto, o PR Management não foi projetado para classificar automaticamente o tipo de módulo afetado pela alteração; ele apenas informa que a PR está 'pronta para revisão', sem destacar que o conteúdo da mudança envolve lógica de controle de acesso. A InfoPrivSec, por sua vez, gerencia uma fila com dezenas de PRs pendentes e prioriza a revisão com base na contagem de linhas alteradas, conforme seu modelo de processo interno — uma heurística adotada porque historicamente PRs pequenas tendiam a ser de baixo risco. Como a alteração no middleware envolve poucas linhas de código (uma mudança em uma condição de verificação de papel), a InfoPrivSec a classifica como baixa prioridade em seu modelo de processo e não chega a revisá-la dentro do prazo do sprint. O Pipeline Orchestrator, operando corretamente segundo a configuração vigente — que não exige bloqueio por aprovação explícita da InfoPrivSec para PRs pequenas — permite que o Developer realize o merge. Nenhum componente falhou: o PR Management informou o que estava configurado para informar, a InfoPrivSec seguiu sua heurística de priorização, e o Pipeline Orchestrator aplicou exatamente a política configurada. A condição perigosa surgiu da combinação entre um modelo de processo que usa tamanho da PR como proxy de risco e a ausência de um sinalizador estrutural que diferencie 'PR pequena e de baixo risco' de 'PR pequena, porém crítica para o controle de acesso'.

UCA Relacionada	UCA-IP-1: A InfoPrivSec NÃO FORNECE a ação de controle Review Code quando a Pull Request modifica lógica de autenticação, autorização ou controle de acesso, e a alteração é integrada à branch principal sem revisão. [H-1, H-2]
Fatores Causais	• Modelo de processo da InfoPrivSec baseado em heurística inadequada (tamanho da PR) para estimar risco de privacidade/segurança • Ausência de feedback estruturado do PR Management indicando o tipo de módulo afetado (autenticação/autorização) • Configuração do Pipeline Orchestrator não exige aprovação obrigatória da InfoPrivSec antes do merge para PRs classificadas como pequenas
Solução Refinada	• Implementar classificação automática de PRs por caminho de arquivo afetado (ex.: módulos de auth/, middleware/, rbac/) e exibir esse rótulo no feedback enviado à InfoPrivSec, independentemente do tamanho da alteração • Configurar o Pipeline Orchestrator (gate de merge) para exigir aprovação explícita da InfoPrivSec sempre que o rótulo de 'controle de acesso' estiver presente, removendo a contagem de linhas como critério de dispensa • Reforça diretamente a CLC-IP-1, tornando a obrigatoriedade da revisão verificável tecnicamente, e não apenas dependente do julgamento do revisor

Cenário de Perda 2 — Relacionado à UCA-IP-2

UCA Relacionada	UCA-IP-1: A InfoPrivSec NÃO FORNECE a ação de controle Review Code quando a Pull Request modifica lógica de autenticação, autorização ou controle de acesso, e a alteração é integrada à branch principal sem revisão. [H-1, H-2]
Controladores Envolvidos	• InfoPrivSec • PR Management • Developer
Arquétipo do Cenário	Classe 2 — Feedback Inadequado / Falta de Informação para o Controlador

UCA Relacionada	UCA-IP-1: A InfoPrivSec NÃO FORNECE a ação de controle Review Code quando a Pull Request modifica lógica de autenticação, autorização ou controle de acesso, e a alteração é integrada à branch principal sem revisão. [H-1, H-2]
Cenário de Alto Nível	O feedback recebido pelo InfoPrivSec a partir do PR Management era tecnicamente correto, mas não continha informação suficiente para que a InfoPrivSec identificasse a necessidade de revisão obrigatória, resultando na ausência da ação de controle Review Code.
Solução de Alto Nível	O PR Management deve sinalizar explicitamente, como parte do feedback rotineiro enviado à InfoPrivSec, sempre que uma submissão alterar arquivos ou módulos associados a autenticação, autorização ou controle de acesso.

UCA Relacionada	UCA-IP-1: A InfoPrivSec NÃO FORNECE a ação de controle Review Code quando a Pull Request modifica lógica de autenticação, autorização ou controle de acesso, e a alteração é integrada à branch principal sem revisão. [H-1, H-2]
Cenário Refinado	Um desenvolvedor abre uma Pull Request que modifica o middleware de autorização de API responsável por validar o escopo de permissões de acesso a prontuários eletrônicos. O PR Management opera exatamente conforme especificado: gera corretamente o status da PR, calcula a cobertura de testes e disponibiliza esses dados à InfoPrivSec através do canal de feedback padrão (PR Status). Entretanto, o PR Management não foi projetado para classificar automaticamente o tipo de módulo afetado pela alteração; ele apenas informa que a PR está 'pronta para revisão', sem destacar que o conteúdo da mudança envolve lógica de controle de acesso. A InfoPrivSec, por sua vez, gerencia uma fila com dezenas de PRs pendentes e prioriza a revisão com base na contagem de linhas alteradas, conforme seu modelo de processo interno — uma heurística adotada porque historicamente PRs pequenas tendiam a ser de baixo risco. Como a alteração no middleware envolve poucas linhas de código (uma mudança em uma condição de verificação de papel), a InfoPrivSec a classifica como baixa prioridade em seu modelo de processo e não chega a revisá-la dentro do prazo do sprint. O Pipeline Orchestrator, operando corretamente segundo a configuração vigente — que não exige bloqueio por aprovação explícita da InfoPrivSec para PRs pequenas — permite que o Developer realize o merge. Nenhum componente falhou: o PR Management informou o que estava configurado para informar, a InfoPrivSec seguiu sua heurística de priorização, e o Pipeline Orchestrator aplicou exatamente a política configurada. A condição perigosa surgiu da combinação entre um modelo de processo que usa tamanho da PR como proxy de risco e a ausência de um sinalizador estrutural que diferencie 'PR pequena e de baixo risco' de 'PR pequena, porém crítica para o controle de acesso'.

UCA Relacionada	UCA-IP-1: A InfoPrivSec NÃO FORNECE a ação de controle Review Code quando a Pull Request modifica lógica de autenticação, autorização ou controle de acesso, e a alteração é integrada à branch principal sem revisão. [H-1, H-2]
Fatores Causais	• Modelo de processo da InfoPrivSec baseado em heurística inadequada (tamanho da PR) para estimar risco de privacidade/segurança • Ausência de feedback estruturado do PR Management indicando o tipo de módulo afetado (autenticação/autorização) • Configuração do Pipeline Orchestrator não exige aprovação obrigatória da InfoPrivSec antes do merge para PRs classificadas como pequenas
Solução Refinada	• Implementar classificação automática de PRs por caminho de arquivo afetado (ex.: módulos de auth/, middleware/, rbac/) e exibir esse rótulo no feedback enviado à InfoPrivSec, independentemente do tamanho da alteração • Configurar o Pipeline Orchestrator (gate de merge) para exigir aprovação explícita da InfoPrivSec sempre que o rótulo de 'controle de acesso' estiver presente, removendo a contagem de linhas como critério de dispensa • Reforçar diretamente a CLC-IP-1, tornando a obrigatoriedade da revisão verificável tecnicamente, e não apenas dependente do julgamento do revisor

Cenário de Perda 3 — Relacionado à UCA-IP-3

UCA Relacionada	UCA-IP-3: A InfoPrivSec NÃO FORNECE a ação de controle Review Code quando a Pull Request está vinculada à correção de vulnerabilidade conhecida ou não conformidade com a LGPD, e a revisão é omitida por pressão de tempo. [H-1, H-2, H-3]
Controladores Envolvidos	• InfoPrivSec • SisAPEC Operations Management • Developer
Arquétipo do Cenário	Classe 1 — Comportamento Inseguro do Controlador (Objetivos Conflitantes)

UCA Relacionada	UCA-IP-3: A InfoPrivSec NÃO FORNECE a ação de controle Review Code quando a Pull Request está vinculada à correção de vulnerabilidade conhecida ou não conformidade com a LGPD, e a revisão é omitida por pressão de tempo. [H-1, H-2, H-3]
Cenário de Alto Nível	A InfoPrivSec recebeu feedback correto e completo sobre a urgência da correção, mas, diante de objetivos conflitantes entre velocidade de remediação e exaustividade da revisão, decidiu confiar isoladamente na varredura automatizada e não fornecer sua própria revisão.
Solução de Alto Nível	Estabelecer uma política organizacional explícita que proíba a dispensa da revisão humana da InfoPrivSec para PRs vinculadas a vulnerabilidades conhecidas, independentemente da pressão de prazo, com escalonamento automático caso o prazo da SLA de remediação esteja em risco.

UCA Relacionada	UCA-IP-3: A InfoPrivSec NÃO FORNECE a ação de controle Review Code quando a Pull Request está vinculada à correção de vulnerabilidade conhecida ou não conformidade com a LGPD, e a revisão é omitida por pressão de tempo. [H-1, H-2, H-3]
Cenário Refinado	A ANPD emite um alerta de incidente de segurança informando que uma vulnerabilidade de exposição de dados está sendo ativamente monitorada em sistemas de saúde similares ao SisAPEC. A SisAPEC Operations Management, agindo corretamente segundo seu mandato, comunica à equipe de DevSecOps uma exigência de remediação dentro de 24 horas, repassando integralmente essa informação à InfoPrivSec. Um Developer prepara rapidamente uma correção e a varredura automatizada de segurança é executada e retorna 'aprovada' para o trecho corrigido — o scanner funciona corretamente e detecta que o padrão vulnerável específico foi removido. A InfoPrivSec, sob a pressão legítima do prazo de 24 horas e avaliando que a varredura automatizada já confirmou a ausência do padrão vulnerável conhecido, decide que uma revisão manual completa consumiria tempo crítico e opta por não revisar a PR, permitindo a integração apenas com base no resultado do scanner. A correção, entretanto, introduz uma nova condição de borda: ao remover o padrão vulnerável original, o desenvolvedor também removeu, sem perceber, uma validação de escopo de permissão que dependia da mesma linha de código — algo que o scanner automatizado não está programado para avaliar, pois sua finalidade é apenas confirmar a ausência de padrões vulneráveis conhecidos, não avaliar a corretude lógica completa da correção. Nenhum componente falhou: a ANPD, a Operations Management, o Developer e o scanner cumpriram exatamente seus papéis especificados. O perigo surgiu porque a InfoPrivSec, diante de um conflito real entre dois objetivos legítimos do sistema (remediar rapidamente vs. revisar com profundidade), priorizou a velocidade, e nenhuma política formal proibia essa escolha em casos de vulnerabilidades conhecidas.

UCA Relacionada	UCA-IP-3: A InfoPrivSec NÃO FORNECE a ação de controle Review Code quando a Pull Request está vinculada à correção de vulnerabilidade conhecida ou não conformidade com a LGPD, e a revisão é omitida por pressão de tempo. [H-1, H-2, H-3]
Fatores Causais	• Objetivos conflitantes entre velocidade de remediação sob pressão regulatória e profundidade da revisão humana • Ausência de política organizacional que explicita que a aprovação automatizada não substitui a revisão humana em correções de vulnerabilidades conhecidas • Escopo do scanner automatizado limitado à detecção do padrão vulnerável original, sem capacidade de avaliar efeitos colaterais lógicos da correção
Solução Refinada	• Instituir regra de pipeline que impeça o merge de PRs rotuladas como 'correção de vulnerabilidade conhecida' sem aprovação humana explícita da InfoPrivSec, mesmo sob prazos críticos • Criar um canal de escalonamento (ex.: revisão em par/dupla revisão acelerada) para casos urgentes, evitando que a única alternativa seja dispensar a revisão • Reforçar a CLC-IP-3, formalizando a exigência de evidências adicionais além da varredura automatizada

Cenário de Perda 4 — Relacionado à UCA-IP-4

UCA Relacionada	UCA-IP-4: A InfoPrivSec FORNECE a ação de controle Review Code, aprovando a PR, quando a alteração introduz dados sensíveis de saúde em logs, mensagens de erro ou mecanismos de observabilidade, sem identificar a exposição. [H-1, H-3]
Controladores Envolvidos	• InfoPrivSec • Developer • Site Reliability Engineer (SRE)
Arquétipo do Cenário	Classe 1 — Comportamento Inseguro do Controlador (Modelo de Processo Incompleto)
Cenário de Alto Nível	A InfoPrivSec realizou a revisão dentro do escopo que considerava adequado, mas seu modelo de processo não contemplava a verificação de caminhos de log e observabilidade como parte rotineira da checklist de aprovação.

UCA Relacionada	UCA-IP-4: A InfoPrivSec FORNECE a ação de controle Review Code, aprovando a PR, quando a alteração introduz dados sensíveis de saúde em logs, mensagens de erro ou mecanismos de observabilidade, sem identificar a exposição. [H-1, H-3]
Solução de Alto Nível	Incluir explicitamente, na checklist formal de revisão da InfoPrivSec, a verificação de todo caminho de código que grave dados em logs, mensagens de erro ou ferramentas de monitoramento.
Cenário Refinado	Um Developer implementa uma melhoria no tratamento de exceções de um serviço clínico, adicionando uma chamada de log que registra o objeto completo da exceção para fins de depuração, incluindo, sem intenção maliciosa, o payload da requisição que contém o nome completo e o diagnóstico do paciente. O código está sintaticamente correto, passa todos os testes automatizados e a varredura de segurança aprova a submissão, pois nenhum padrão de vulnerabilidade técnica conhecida está presente. A InfoPrivSec realiza a revisão da PR de forma genuína e atenta, examinando a lógica de negócio, a cobertura de testes e a ausência de vulnerabilidades de segurança tradicionais (injeção, autenticação). Seu modelo de processo e sua checklist de revisão, construídos a partir das diretrizes vigentes da organização, focam primariamente em controle de acesso e validação de entrada — sem incluir, como item obrigatório, a inspeção de chamadas de logging quanto à presença de dados pessoais. A InfoPrivSec aprova a PR de boa-fé, certificando-a como segura. O SRE, ao receber posteriormente um alerta de erro real em produção, observa nos logs do sistema de observabilidade o conteúdo completo da exceção — e, com isso, dados sensíveis do paciente passam a residir em um sistema de monitoramento de terceiros acessível à equipe de operações, fora dos controles de acesso da aplicação principal. Nenhum componente falhou: o Developer escreveu código funcional, o scanner avaliou corretamente o que estava em seu escopo, a InfoPrivSec seguiu sua checklist vigente com atenção, e o SRE apenas observou o comportamento esperado da ferramenta de observabilidade. O perigo nasceu de uma lacuna estrutural na definição do escopo de revisão da InfoPrivSec, que nunca incluiu logging como uma superfície de risco de privacidade.

UCA Relacionada	UCA-IP-4: A InfoPrivSec FORNECE a ação de controle Review Code, aprovando a PR, quando a alteração introduz dados sensíveis de saúde em logs, mensagens de erro ou mecanismos de observabilidade, sem identificar a exposição. [H-1, H-3]
Fatores Causais	• Checklist formal de revisão da InfoPrivSec não contempla verificação de exposição de dados pessoais em logs, mensagens de erro ou observabilidade • Varredura automatizada de segurança não é projetada para detectar PII/PHI em chamadas de logging • Ausência de padronização (ex.: biblioteca de logging com mascaramento automático) que reduza a dependência da revisão manual para esse risco específico
Solução Refinada	• Atualizar formalmente a checklist de revisão da InfoPrivSec para incluir item obrigatório de verificação de chamadas de log/erro/observabilidade quanto à presença de dados pessoais sensíveis • Adotar biblioteca de logging padronizada com mascaramento automático de campos sensíveis conhecidos, reduzindo a dependência exclusiva da revisão manual • Implementa diretamente a CLC-IP-4, tornando a exigência de mascaramento/remoção verificável antes da aprovação

Cenário de Perda 5 — Relacionado à UCA-IP-5

UCA Relacionada	UCA-IP-5: A InfoPrivSec FORNECE a ação de controle Review Code, aprovando a PR, quando a alteração implementa controles de autenticação/autorização inadequados, apesar de identificáveis no código e nos resultados da varredura automatizada. [H-1, H-2]
Controladores Envolvidos	• InfoPrivSec • Developer • Staff Engineer
Arquétipo do Cenário	Classe 1 — Comportamento Inseguro do Controlador (Carga de Trabalho / Atenção)
Cenário de Alto Nível	A InfoPrivSec dispunha de toda a informação necessária — incluindo um alerta de baixa severidade do scanner — mas, sob carga elevada de revisões pendentes, não atribuiu a esse alerta a atenção necessária para reconhecer a gravidade real no contexto clínico.

UCA Relacionada	UCA-IP-5: A InfoPrivSec FORNECE a ação de controle Review Code, aprovando a PR, quando a alteração implementa controles de autenticação/autorização inadequados, apesar de identificáveis no código e nos resultados da varredura automatizada. [H-1, H-2]
Solução de Alto Nível	Os resultados da varredura automatizada relacionados a controle de acesso devem ser destacados com prioridade visual elevada quando o módulo afetado lidar com dados de pacientes, independentemente da severidade técnica padrão atribuída pela ferramenta.
Cenário Refinado	Um Developer implementa um novo endpoint de consulta a resultados de exames laboratoriais. Por simplicidade, o papel padrão atribuído ao endpoint é amplo (permite leitura por qualquer usuário autenticado, não apenas pelo profissional responsável pelo paciente), uma escolha de design que o Developer considera temporária e documenta em um comentário no código. A varredura automatizada de segurança identifica corretamente a ausência de verificação de escopo de permissão no endpoint e gera um alerta — classificado pela ferramenta, segundo sua própria escala de severidade técnica, como 'informativo', pois não representa uma vulnerabilidade de injeção ou exposição direta de credenciais, categorias para as quais a ferramenta foi calibrada com maior severidade. A InfoPrivSec, revisando simultaneamente um lote de oito Pull Requests no mesmo dia — uma carga de trabalho normal segundo a alocação de recursos da equipe —, examina os resultados da varredura e, vendo a marcação 'informativo', aplica seu modelo de processo de priorização (que trata alertas informativos como de baixo risco) e aprova a PR sem aprofundar a investigação sobre o real impacto do escopo de permissão amplo em dados clínicos. Todos os componentes operaram conforme especificado: o Developer documentou sua decisão, o scanner classificou o alerta segundo sua escala técnica padrão, e a InfoPrivSec aplicou sua heurística de priorização sob uma carga de trabalho normal. O perigo emergiu porque a escala de severidade do scanner não é sensível ao contexto de dados de saúde, e nenhum mecanismo eleva esse tipo de alerta quando o endpoint afetado envolve pacientes.

UCA Relacionada	UCA-IP-5: A InfoPrivSec FORNECE a ação de controle Review Code, aprovando a PR, quando a alteração implementa controles de autenticação/autorização inadequados, apesar de identificáveis no código e nos resultados da varredura automatizada. [H-1, H-2]
Fatores Causais	• Escala de severidade da varredura automatizada não diferencia contexto de dados de saúde, tratando falhas de escopo de permissão como 'informativas' por padrão • Modelo de processo da InfoPrivSec usa a severidade reportada pela ferramenta como proxy direto de prioridade de atenção, sem ajuste para o domínio clínico • Carga de revisão simultânea (múltiplas PRs no mesmo período) reduz a profundidade de análise dedicada a cada alerta individual
Solução Refinada	• Reclassificar, via política de configuração do scanner, qualquer alerta de controle de acesso em módulos rotulados como 'dados de pacientes' para severidade elevada, independentemente da escala técnica padrão • Limitar o número de PRs de alto risco (acesso a dados sensíveis) atribuídas à InfoPrivSec por período, para preservar profundidade de análise • Operacionaliza a CLC-IP-5, assegurando que escopos de permissão inadequados sejam tratados como bloqueadores de aprovação

Cenário de Perda 6 — Relacionado à UCA-IP-6

UCA Relacionada	UCA-IP-6: A InfoPrivSec FORNECE a ação de controle Review Code, aprovando a PR, quando permanecem sem solução a manipulação inadequada de dados clínicos, validações desativadas, auditoria enfraquecida ou evidências insuficientes/inconsistentes. [H-2, H-4, H-7, H-8]
Controladores Envolvidos	• InfoPrivSec • Pipeline Orchestrator • CI/CD Pipeline
Arquétipo do Cenário	Classe 2 — Feedback Inadequado / Informação Inconsistente
Cenário de Alto Nível	A InfoPrivSec recebeu do CI/CD Pipeline um status de varredura que, embora tecnicamente correto, era ambíguo o suficiente para ser interpretado como suficiente para aprovação, quando na realidade representava uma cobertura incompleta.

UCA Relacionada	UCA-IP-6: A InfoPrivSec FORNECE a ação de controle Review Code, aprovando a PR, quando permanecem sem solução a manipulação inadequada de dados clínicos, validações desativadas, auditoria enfraquecida ou evidências insuficientes/inconsistentes. [H-2, H-4, H-7, H-8]
Solução de Alto Nível	O status de varredura reportado à InfoPrivSec deve distinguir explicitamente entre 'aprovado com cobertura completa' e 'aprovado com módulos não escaneados', eliminando estados ambíguos no feedback.
Cenário Refinado	Uma submissão modifica simultaneamente uma rotina de validação de dados clínicos e a configuração do scanner de segurança (para acomodar uma nova dependência). O CI/CD Pipeline executa a varredura sobre o código-fonte modificado, mas, devido à própria mudança de configuração incluída na PR, um dos módulos de validação clínica fica fora do escopo coberto pelo scanner — um comportamento absolutamente correto e esperado da ferramenta diante da nova configuração que lhe foi fornecida, não uma falha. O CI/CD Pipeline retorna o status agregado da execução como 'aprovado', pois, dentro do escopo que efetivamente analisou, nenhuma vulnerabilidade foi encontrada. O sistema não distingue, em seu relatório padrão, entre 'aprovado — cobertura total' e 'aprovado — cobertura parcial devido a mudança de escopo'. A InfoPrivSec, ao revisar o relatório do Pipeline Orchestrator, observa o rótulo 'aprovado' e, combinado com a pressão normal de prazo do sprint, interpreta — de forma plausível, dado a informação disponível — que toda a submissão foi adequadamente verificada, incluindo a rotina de validação clínica modificada. A PR é aprovada, e a rotina de validação, que de fato havia sido alterada de forma a aceitar um intervalo de dosagem fora do padrão clínico esperado, é integrada sem que essa condição específica fosse detectada por revisão humana ou automatizada. Nenhum componente atuou fora de sua especificação: o scanner escaneou o que a configuração vigente determinava, o pipeline relatou fielmente seu resultado interno, e a InfoPrivSec interpretou racionalmente um rótulo agregado. A causa raiz está no formato do feedback — um único rótulo binário 'aprovado/reprovado' que esconde a granularidade real da cobertura da varredura.

UCA Relacionada	UCA-IP-6: A InfoPrivSec FORNECE a ação de controle Review Code, aprovando a PR, quando permanecem sem solução a manipulação inadequada de dados clínicos, validações desativadas, auditoria enfraquecida ou evidências insuficientes/inconsistentes. [H-2, H-4, H-7, H-8]
Fatores Causais	• Relatório de status da varredura automatizada utiliza rótulo agregado binário, sem distinguir cobertura completa de cobertura parcial • Alteração de configuração do scanner dentro da própria PR reduz silenciosamente o escopo de análise sem alertar o revisor humano • Modelo de processo da InfoPrivSec trata 'aprovado' como sinônimo de 'totalmente verificado', sem mecanismo para questionar a cobertura
Solução Refinada	• Alterar o relatório do CI/CD Pipeline para exibir explicitamente a lista de módulos efetivamente cobertos pela varredura, destacando qualquer redução de escopo causada pela própria PR • Exigir aprovação adicional (ex.: segundo revisor) sempre que uma PR alterar simultaneamente a configuração do scanner e código de negócio • Operacionaliza a CLC-IP-6, garantindo que evidências insuficientes ou inconsistentes sejam tratadas como impedimento explícito à aprovação

Cenário de Perda 7 — Relacionado à UCA-IP-7

UCA Relacionada	UCA-IP-7: A InfoPrivSec FORNECE a ação de controle Review Code antes que os resultados dos scans automatizados (SAST/SCA) estejam disponíveis. [H-1, H-2]
Controladores Envolvidos	• InfoPrivSec • Pipeline Orchestrator • CI/CD Pipeline
Arquétipo do Cenário	Classe 4 — Ações de Controle Conflitantes / Sincronização Inadequada
Cenário de Alto Nível	A InfoPrivSec e o CI/CD Pipeline operam como dois processos paralelos sem um mecanismo de sincronização que impeça a revisão humana de avançar antes da conclusão da varredura automatizada.
Solução de Alto Nível	A interface de revisão utilizada pela InfoPrivSec deve bloquear estruturalmente a emissão de aprovação enquanto o status da varredura automatizada não estiver definido como concluído.

UCA Relacionada	UCA-IP-7: A InfoPrivSec FORNECE a ação de controle Review Code antes que os resultados dos scans automatizados (SAST/SCA) estejam disponíveis. [H-1, H-2]
Cenário Refinado	Um Developer abre uma PR no final do expediente e a notificação correspondente é enviada à InfoPrivSec, que está disponível e decide revisar a alteração imediatamente, como parte de sua prática usual de revisar PRs assim que notificada para reduzir o tempo de ciclo. A interface de revisão exibe a PR com seu conteúdo completo, pois o repositório de código já contém o commit. O CI/CD Pipeline, por sua vez, está executando a varredura automatizada em segundo plano — um processo que, para esta submissão específica (que inclui uma atualização de dependências), leva alguns minutos adicionais para concluir, um tempo de execução normal e esperado para esse tipo de verificação, não uma demora anômala. A interface de revisão utilizada pela InfoPrivSec exibe a seção de 'Resultados da Varredura' como 'em execução', mas não impede tecnicamente a emissão do botão de aprovação. A InfoPrivSec, avaliando a lógica de negócio da alteração como correta e considerando que varreduras anteriores do mesmo desenvolvedor raramente apontam problemas, decide aprovar a PR sem aguardar a conclusão do scan, registrando a aprovação enquanto o resultado real do SCA — que, uma vez concluído minutos depois, identificaria uma dependência transitiva vulnerável introduzida pela atualização — ainda não havia sido gerado. Nenhum componente falhou: o Developer submeteu a PR normalmente, o CI/CD Pipeline executou a varredura no tempo que efetivamente precisava, e a InfoPrivSec tomou uma decisão dentro da interface disponível. A condição perigosa decorre exclusivamente da ausência de um bloqueio estrutural entre os dois fluxos paralelos — revisão humana e varredura automatizada — que permitiu que a aprovação fosse registrada antes que a informação do scanner estivesse disponível.
Fatores Causais	• Ausência de bloqueio estrutural (gate técnico) que impeça a emissão de aprovação humana antes da conclusão da varredura automatizada • Interface de revisão exibe o status do scan como informativo, não como pré-condição obrigatória para o botão de aprovação • Prática informal de revisão imediata da InfoPrivSec, sem verificação explícita da disponibilidade de todos os insumos antes de decidir

UCA Relacionada	UCA-IP-7: A InfoPrivSec FORNECE a ação de controle Review Code antes que os resultados dos scans automatizados (SAST/SCA) estejam disponíveis. [H-1, H-2]
Solução Refinada	• Implementar gate técnico no Pipeline Orchestrator que desabilite o botão/ação de aprovação da InfoPrivSec até que o status da varredura SAST/SCA seja 'concluído' (aprovado, reprovado ou incompleto) • Exibir alerta explícito na interface de revisão impedindo a submissão de uma decisão de aprovação enquanto o status permanecer 'em execução' • Operacionaliza a CLC-IP-7 como controle técnico, e não apenas como procedimento dependente da disciplina do revisor

Cenário de Perda 8 — Relacionado à UCA-IP-8

UCA Relacionada	UCA-IP-8: A InfoPrivSec FORNECE a ação de controle Review Code após o código já ter sido integrado ao branch principal, de forma retroativa. [H-1, H-2, H-3, H-4]
Controladores Envolvidos	• InfoPrivSec • Developer • Pipeline Orchestrator
Arquétipo do Cenário	Classe 4 — Ações de Controle Conflitantes (Caminho Alternativo de Integração)
Cenário de Alto Nível	Existe, dentro da configuração legítima do repositório, um caminho de integração (hotfix direto) que não exige a aprovação prévia da InfoPrivSec, e esse caminho foi utilizado para uma alteração que deveria ter seguido o fluxo padrão de revisão.
Solução de Alto Nível	Eliminar ou restringir severamente caminhos de integração alternativos que possibilitem o merge sem aprovação prévia da InfoPrivSec, sobretudo para alterações que afetem dados de pacientes.

UCA Relacionada	UCA-IP-8: A InfoPrivSec FORNECE a ação de controle Review Code após o código já ter sido integrado ao branch principal, de forma retroativa. [H-1, H-2, H-3, H-4]
Cenário Refinado	O repositório do SisAPEC possui, por desenho organizacional legítimo, uma branch de hotfix configurada para permitir que membros seniores da equipe de Staff Engineering realizem integrações de emergência sem aguardar o ciclo completo de revisão, destinada a cenários de indisponibilidade crítica do sistema durante o atendimento ao paciente. Um Staff Engineer identifica uma instabilidade na funcionalidade de geração de relatórios e, avaliando corretamente que se trata de uma situação de indisponibilidade que se encaixa na política de hotfix, integra uma correção diretamente pela branch de emergência — uma ação plenamente autorizada e dentro do escopo de sua função. A correção, contudo, modifica também a forma como o relatório registra o identificador do paciente no cabeçalho do arquivo gerado, introduzindo, sem que o Staff Engineer fosse esperado a perceber essa implicação (já que seu foco era restaurar a disponibilidade), uma alteração na forma como dados são auditados. A InfoPrivSec é notificada e realiza a revisão dias depois, conforme o procedimento de revisão retroativa obrigatória para hotfixes — exatamente como o processo determina. Quando a InfoPrivSec identifica o problema de auditoria na revisão retroativa, o relatório já havia sido gerado e distribuído para a unidade de saúde, e a janela de exposição já havia se concretizado. Nenhum componente falhou: a política de hotfix existe por um motivo legítimo (disponibilidade), o Staff Engineer a usou corretamente, e a InfoPrivSec cumpriu seu papel de revisão retroativa como prescrito. O perigo nasce do próprio desenho do processo, que permite, por necessidade operacional genuína, um caminho de integração sem o controle preventivo da InfoPrivSec.

UCA Relacionada	UCA-IP-8: A InfoPrivSec FORNECE a ação de controle Review Code após o código já ter sido integrado ao branch principal, de forma retroativa. [H-1, H-2, H-3, H-4]
Fatores Causais	• Política organizacional de hotfix permite merge sem aprovação prévia da InfoPrivSec como mecanismo legítimo para emergências de disponibilidade • Revisão retroativa, embora realizada conforme o procedimento, ocorre necessariamente após a janela de exposição já ter se concretizado • Ausência de uma verificação mínima e automatizada (ainda que mais leve) de impacto em privacidade/auditoria mesmo no fluxo de hotfix
Solução Refinada	• Manter o caminho de hotfix para disponibilidade, mas adicionar uma verificação automatizada obrigatória e rápida (ex.: checagem estática de campos de auditoria/PII) mesmo nesse fluxo, antes da integração • Restringir o uso do caminho de hotfix exclusivamente a correções que não envolvam módulos relacionados a dados de pacientes; alterações nesses módulos, mesmo emergenciais, devem exigir aprovação remota expressa da InfoPrivSec (ainda que abreviada) • Reforça a CLC-IP-8, tornando o caráter preventivo da revisão exigível mesmo em cenários de exceção operacional

Cenário de Perda 9 — Relacionado à UCA-IP-9

UCA Relacionada	UCA-IP-9: A InfoPrivSec FORNECE a ação de controle Review Code fora de ordem, aprovando uma submissão que depende de outra ainda não revisada, sem considerar o impacto combinado. [H-1, H-2, H-3]
Controladores Envolvidos	• InfoPrivSec • PR Management • Developer
Arquétipo do Cenário	Classe 2 — Feedback Inadequado (Dependências entre Submissões não Visíveis)
Cenário de Alto Nível	O PR Management não expõe, em seu feedback padrão à InfoPrivSec, as relações de dependência entre Pull Requests abertas simultaneamente, levando o controlador a avaliar cada submissão isoladamente.
Solução de Alto Nível	O PR Management deve identificar e reportar explicitamente, no feedback enviado à InfoPrivSec, quando uma PR depende de branches ou alterações presentes em outra PR ainda não revisada.

UCA Relacionada	UCA-IP-9: A InfoPrivSec FORNECE a ação de controle Review Code fora de ordem, aprovando uma submissão que depende de outra ainda não revisada, sem considerar o impacto combinado. [H-1, H-2, H-3]
Cenário Refinado	Dois desenvolvedores trabalham em funcionalidades relacionadas: um implementa uma alteração na lógica de autorização de um endpoint (PR-A, ainda pendente de revisão), e outro implementa uma nova tela que consome esse mesmo endpoint (PR-B, criada a partir da branch de PR-A para reaproveitar o código ainda não integrado). Essa prática de desenvolvimento em branches encadeadas é uma forma de trabalho aceita e habitual na equipe. O PR Management, operando conforme projetado, exibe corretamente o diff de PR-B em relação à branch principal, mas — por não ter sido construído para rastrear relações de dependência entre branches de feature ainda não integradas — apresenta PR-B como uma submissão autocontida, sem qualquer indicação de que parte de seu comportamento depende da lógica de autorização ainda não revisada em PR-A. A InfoPrivSec revisa PR-B isoladamente: o código da nova tela está bem escrito, os testes passam, e a lógica de exibição de dados parece adequada quando analisada por si só. A InfoPrivSec aprova PR-B sem avaliar o impacto combinado com PR-A, pois nenhuma informação disponível em seu modelo de processo sugeria a existência dessa dependência. O efeito perigoso só emerge da interação: a lógica de autorização ainda não revisada em PR-A continha uma falha de escopo que, isoladamente, talvez fosse identificada na revisão de PR-A; combinada com a nova tela de PR-B, essa falha permite que a interface exiba dados de pacientes para um perfil de usuário sem a permissão adequada. Nenhum componente falhou: o PR Management exibiu corretamente o que estava em seu escopo de rastreamento, e a InfoPrivSec avaliou racionalmente a informação disponível. A causa é a invisibilidade estrutural da dependência entre as duas submissões.

UCA Relacionada	UCA-IP-9: A InfoPrivSec FORNECE a ação de controle Review Code fora de ordem, aprovando uma submissão que depende de outra ainda não revisada, sem considerar o impacto combinado. [H-1, H-2, H-3]
Fatores Causais	• PR Management não rastreia nem expõe dependências entre branches de feature ainda não integradas à branch principal • Modelo de processo da InfoPrivSec trata cada PR como unidade de avaliação independente, sem mecanismo para sinalizar avaliação conjunta • Prática de desenvolvimento em branches encadeadas, embora legítima, aumenta o risco de avaliação isolada incompleta
Solução Refinada	• Implementar no PR Management a detecção automática de branches encadeadas (PRs criadas a partir de outra branch de feature não integrada) e exibir esse relacionamento de forma destacada à InfoPrivSec • Exigir que a InfoPrivSec avalie conjuntamente PRs identificadas como dependentes, emitindo uma única decisão de aprovação combinada • Implementa a CLC-IP-9, tornando verificável a checagem de impacto combinado antes da aprovação

Cenário de Perda 10 — Relacionado à UCA-IP-10

UCA Relacionada	UCA-IP-10: A InfoPrivSec INTERROMPE a ação de controle Review Code cedo demais, aprovando a submissão após analisar apenas parte dos arquivos modificados. [H-1, H-2]
Controladores Envolvidos	• InfoPrivSec • Code Repository
Arquétipo do Cenário	Classe 1 — Comportamento Inseguro do Controlador (Interface de Revisão Inadequada)
Cenário de Alto Nível	A interface de revisão apresentada à InfoPrivSec não comunica de forma proeminente a quantidade total de arquivos modificados, permitindo que o controlador conclua a revisão acreditando, de boa-fé, ter examinado tudo o que era necessário.
Solução de Alto Nível	A interface de revisão deve exigir confirmação explícita de que todos os arquivos modificados foram visualizados antes de habilitar a opção de aprovação.

UCA Relacionada	UCA-IP-10: A InfoPrivSec INTERROMPE a ação de controle Review Code cedo demais, aprovando a submissão após analisar apenas parte dos arquivos modificados. [H-1, H-2]
Cenário Refinado	Uma PR modifica catorze arquivos, sendo doze relacionados à interface visual de um formulário clínico e dois relacionados a uma rotina de auditoria que registra alterações em campos de prontuário. A ferramenta de revisão de código exibe os arquivos paginados, mostrando dez por página — um comportamento padrão e correto da ferramenta. A InfoPrivSec revisa cuidadosamente a primeira página, composta majoritariamente pelos arquivos de interface visual, e considera a alteração coerente e de baixo risco aparente, já que a maior parte do que viu são ajustes de layout. Por uma sobrecarga normal de tarefas no dia (reuniões agendadas em sequência), a InfoPrivSec aprova a PR a partir da primeira página, sem perceber que existe uma segunda página com os dois arquivos restantes, pois a interface não exibe de forma destacada o total de arquivos pendentes de visualização. Os dois arquivos não examinados continham, de fato, uma alteração na rotina de auditoria que reduzia a granularidade dos registros de log (de nível de campo para nível de formulário), uma mudança que comprometeria parcialmente a rastreabilidade exigida pela LGPD para alterações em dados clínicos. Nenhum componente falhou: a ferramenta de revisão paginou os arquivos como projetado, e a InfoPrivSec revisou com atenção genuína o que tinha diante de si. O perigo nasceu da combinação entre uma interface que não destaca proeminentemente arquivos não visualizados e a ausência de uma exigência formal de confirmação de cobertura completa antes da aprovação.
Fatores Causais	• Interface de revisão pagina arquivos modificados sem destacar de forma proeminente a existência de páginas adicionais não visualizadas • Ausência de mecanismo de confirmação obrigatória ('todos os arquivos foram revisados') antes de habilitar a aprovação • Carga normal de tarefas concorrentes no período reduz a probabilidade de verificação manual adicional pelo revisor

UCA Relacionada	UCA-IP-10: A InfoPrivSec INTERROMPE a ação de controle Review Code cedo demais, aprovando a submissão após analisar apenas parte dos arquivos modificados. [H-1, H-2]
Solução Refinada	• Modificar a interface da Code Repository/PR Management para exibir um indicador persistente de progresso ('12 de 14 arquivos visualizados') durante toda a sessão de revisão • Desabilitar tecnicamente o botão de aprovação até que todos os arquivos modificados tenham sido marcados como visualizados pela InfoPrivSec • Operacionaliza a CLC-IP-10 como controle técnico verificável, eliminando a dependência exclusiva da atenção do revisor

Cenário de Perda 11 — Relacionado à UCA-IP-11

UCA Relacionada	UCA-IP-11: A InfoPrivSec MANTÉM a ação de controle Review Code por tempo excessivo, bloqueando indefinidamente uma submissão com correção crítica de segurança ou privacidade. [H-2, H-5]
Controladores Envolvidos	• InfoPrivSec • SisAPEC Operations Management • Developer
Arquétipo do Cenário	Classe 1 — Comportamento Inseguro do Controlador (Objetivos Conflitantes / Ausência de SLA)
Cenário de Alto Nível	A InfoPrivSec, sobrecarregada por múltiplas demandas concorrentes igualmente legítimas e sem um prazo formal definido para correções críticas, posterga repetidamente a decisão sobre a PR sem que isso seja tratado como uma anomalia pelo restante do processo.
Solução de Alto Nível	Definir um prazo máximo (SLA) formal e monitorado para que a InfoPrivSec emita uma decisão (aprovação ou rejeição) sobre PRs rotuladas como correção crítica de segurança ou privacidade.

UCA Relacionada	UCA-IP-11: A InfoPrivSec MANTÉM a ação de controle Review Code por tempo excessivo, bloqueando indefinidamente uma submissão com correção crítica de segurança ou privacidade. [H-2, H-5]
Cenário Refinado	Uma vulnerabilidade ativa de exposição de dados é identificada em produção, e um Developer prepara rapidamente a correção correspondente. A PR é aberta e corretamente rotulada como 'crítica' no sistema de PR Management. Nesse mesmo período, a InfoPrivSec também está conduzindo, com igual prioridade formal, a revisão de um conjunto de alterações de conformidade exigidas por uma auditoria externa agendada para a semana seguinte — uma tarefa igualmente legítima e urgente sob a ótica organizacional. A InfoPrivSec examina a PR crítica, mas identifica uma ambiguidade genuína: a correção resolve a vulnerabilidade, porém também altera ligeiramente o formato de um campo de auditoria, e a InfoPrivSec não tem certeza se essa alteração colateral é aceitável sem consultar o Staff Engineer responsável pelo módulo de auditoria, que está, naquele momento, dedicado à preparação da auditoria externa e não responde imediatamente. Sem um prazo formal definido para decisões sobre PRs críticas, e diante de duas demandas legítimas competindo por sua atenção, a InfoPrivSec mantém a PR em estado 'em análise' por vários dias, aguardando esclarecimento, sem emitir uma rejeição formal (que liberaria o Developer para buscar outra abordagem) nem uma aprovação condicional. A SisAPEC Operations Management, por sua vez, não monitora ativamente o tempo de permanência de PRs críticas em revisão, pois esse não é um indicador formalmente acompanhado pelo processo vigente. Nenhum componente falhou: a InfoPrivSec agiu com cautela razoável diante de uma ambiguidade real, o Staff Engineer estava legitimamente ocupado, e a Operations Management cumpriu seu papel sem um indicador que a alertasse sobre o atraso. O perigo decorre da ausência de um SLA explícito e de um mecanismo de escalonamento que impeça o bloqueio indefinido diante de objetivos conflitantes igualmente legítimos.

UCA Relacionada	UCA-IP-11: A InfoPrivSec MANTÉM a ação de controle Review Code por tempo excessivo, bloqueando indefinidamente uma submissão com correção crítica de segurança ou privacidade. [H-2, H-5]
Fatores Causais	• Ausência de SLA formal e monitorado para decisão da InfoPrivSec sobre PRs rotuladas como críticas • Objetivos conflitantes legítimos (vulnerabilidade ativa vs. preparação de auditoria externa) competindo pela atenção do mesmo controlador • Ausência de mecanismo de escalonamento automático quando uma dúvida bloqueia a decisão por tempo prolongado
Solução Refinada	• Definir e monitorar formalmente um SLA máximo (ex.: 24h) para decisão da InfoPrivSec sobre PRs rotuladas como críticas, com escalonamento automático à SisAPEC Operations Management caso o prazo seja excedido • Estabelecer um canal de consulta prioritária (ex.: revisão em par com disponibilidade garantida) para resolver ambiguidades em PRs críticas sem depender da disponibilidade incerta de um único especialista • Implementa a CLC-IP-11, tornando o prazo de decisão uma exigência verificável e não apenas uma boa prática informal

Cenário de Perda 12 — Relacionado à UCA-IP-12

UCA Relacionada	UCA-IP-12: A InfoPrivSec INTERROMPE a ação de controle Review Code cedo demais quando a submissão inclui lógica complexa de processamento de dados, sem verificar todos os caminhos de execução afetados. [H-3, H-4]
Controladores Envolvidos	• InfoPrivSec • Developer
Arquétipo do Cenário	Classe 1 — Comportamento Inseguro do Controlador (Modelo de Processo Incompleto)
Cenário de Alto Nível	A InfoPrivSec concentrou sua revisão nos caminhos principais de execução da lógica de processamento de dados, pois seu modelo de processo não tratava explicitamente fluxos de exceção como uma categoria obrigatória de verificação para conformidade com a LGPD.

UCA Relacionada	UCA-IP-12: A InfoPrivSec INTERROMPE a ação de controle Review Code cedo demais quando a submissão inclui lógica complexa de processamento de dados, sem verificar todos os caminhos de execução afetados. [H-3, H-4]
Solução de Alto Nível	A checklist de revisão da InfoPrivSec deve exigir, para submissões que envolvam lógica de processamento de dados pessoais com múltiplos caminhos, a verificação explícita de fluxos alternativos e condições de exceção, não apenas do caminho principal.
Cenário Refinado	Um Developer implementa uma nova rotina de triagem automática de risco clínico que processa os dados do paciente por múltiplos caminhos: um caminho principal (paciente com histórico completo), e caminhos de exceção (paciente novo, paciente com dados parcialmente migrados de outro sistema, paciente com consentimento pendente). O código está bem estruturado e claramente documentado quanto à existência desses caminhos alternativos. A InfoPrivSec revisa a PR e examina detalhadamente o caminho principal, confirmando que ele respeita a finalidade de tratamento autorizada e registra adequadamente os logs de auditoria. Encontrando esse caminho satisfatório, e operando sob seu modelo de processo habitual — que trata 'o comportamento típico do sistema' como suficiente para uma aprovação, já que essa abordagem normalmente captura a maior parte do risco —, a InfoPrivSec conclui a revisão e aprova a PR sem examinar com o mesmo rigor os três caminhos de exceção. O caminho de 'paciente com consentimento pendente', especificamente, processa e armazena dados clínicos do paciente antes da confirmação formal do consentimento — uma condição que viola a base legal de tratamento exigida pela LGPD para esse cenário, mas que só se manifesta quando esse fluxo de exceção específico é acionado, o que ocorre em uma minoria dos atendimentos. Nenhum componente falhou: o Developer implementou e documentou corretamente todos os caminhos, e a InfoPrivSec revisou com atenção genuína o que considerava o núcleo da lógica. O perigo nasceu da ausência, no modelo de processo da InfoPrivSec, de uma exigência explícita de cobertura de caminhos de exceção como critério obrigatório de conformidade, e não apenas como uma boa prática deixada ao critério do revisor.

UCA Relacionada	UCA-IP-12: A InfoPrivSec INTERROMPE a ação de controle Review Code cedo demais quando a submissão inclui lógica complexa de processamento de dados, sem verificar todos os caminhos de execução afetados. [H-3, H-4]
Fatores Causais	• Modelo de processo da InfoPrivSec trata o caminho principal de execução como suficiente para certificar conformidade, sem exigência formal de cobertura de caminhos de exceção • Ausência de uma checklist estruturada que liste explicitamente os fluxos alternativos identificados na documentação da PR como itens obrigatórios de verificação • Complexidade da lógica de múltiplos caminhos não é sinalizada ao revisor como um fator que deveria estender o escopo mínimo da revisão
Solução Refinada	• Exigir que toda PR com lógica de processamento de dados pessoais com múltiplos caminhos liste explicitamente, em sua descrição, todos os fluxos alternativos e condições de exceção, como pré-requisito para entrar na fila de revisão • Atualizar a checklist da InfoPrivSec para incluir item obrigatório de verificação individual de cada caminho listado antes da aprovação • Implementa a CLC-IP-12, tornando a cobertura de caminhos de exceção um critério verificável de conclusão da revisão

8. Requisitos Derivados (Task 8)

A partir dos cenários de perda identificados na Seção 7, a Tabela a seguir apresenta os requisitos derivados propostos para mitigar ou eliminar as condições causais identificadas. Cada requisito é rastreável ao(s) cenário(s) de perda que o motivou, seguindo o formato de exemplo apresentado na Tabela 9 do documento de especificação do trabalho.

ID	Requisito Derivado	Cenário(s) Relacionado(s)
DR-1	O PR Management deve classificar automaticamente cada Pull Request quanto ao módulo afetado (ex.: autenticação/autorização, tratamento de dados pessoais), exibindo esse rótulo no feedback enviado à InfoPrivSec independentemente do tamanho da alteração.	Cenário UCA-IP-1
DR-2	O Pipeline Orchestrator deve exigir aprovação explícita da InfoPrivSec antes do merge de qualquer PR rotulada como afetando controle de acesso, eliminando a contagem de linhas como critério de dispensa.	Cenário UCA-IP-1
DR-3	O pipeline DevSecOps deve incluir uma verificação automatizada independente do autorreporte do Developer para identificar fluxos de exportação ou compartilhamento de dados pessoais, atualizando a variável correspondente no modelo de processo da InfoPrivSec.	Cenário UCA-IP-2
DR-4	O template de abertura de Pull Request deve incluir um checklist obrigatório de impacto em dados pessoais, que não possa ser submetido sem preenchimento.	Cenário UCA-IP-2
DR-5	O Pipeline Orchestrator deve impedir tecnicamente o merge de PRs rotuladas como 'correção de vulnerabilidade conhecida' sem aprovação humana explícita da InfoPrivSec, independentemente de prazos críticos de remediação.	Cenário UCA-IP-3
DR-6	A checklist formal de revisão da InfoPrivSec deve incluir item obrigatório de verificação de chamadas de log, mensagens de erro e mecanismos de observabilidade quanto à presença de dados pessoais sensíveis.	Cenário UCA-IP-4

ID	Requisito Derivado	Cenário(s) Relacionado(s)
DR-7	O SisAPEC deve adotar biblioteca de logging padronizada com mascaramento automático de campos sensíveis conhecidos, reduzindo a dependência exclusiva da revisão manual para esse risco.	Cenário UCA-IP-4
DR-8	A varredura automatizada de segurança deve reclassificar para severidade elevada qualquer alerta de controle de acesso identificado em módulos rotulados como relacionados a dados de pacientes.	Cenário UCA-IP-5
DR-9	O relatório de status da varredura automatizada exibido à InfoPrivSec deve distinguir explicitamente cobertura completa de cobertura parcial, listando os módulos efetivamente analisados.	Cenário UCA-IP-6
DR-10	A interface de revisão utilizada pela InfoPrivSec deve desabilitar tecnicamente a ação de aprovação até que o status da varredura SAST/SCA esteja definido como concluído.	Cenário UCA-IP-7
DR-11	O caminho de integração de hotfix deve incluir uma verificação automatizada obrigatória e rápida de impacto em privacidade/auditoria antes da integração, mesmo em cenários de emergência de disponibilidade.	Cenário UCA-IP-8
DR-12	Alterações em módulos relacionados a dados de pacientes, mesmo classificadas como emergenciais, devem exigir aprovação remota expressa (ainda que abreviada) da InfoPrivSec antes da integração via hotfix.	Cenário UCA-IP-8
DR-13	O PR Management deve detectar e exibir de forma destacada relações de dependência entre Pull Requests criadas a partir de branches de feature ainda não integradas.	Cenário UCA-IP-9

ID	Requisito Derivado	Cenário(s) Relacionado(s)
DR-14	A interface de revisão deve exibir um indicador persistente de progresso de cobertura de arquivos modificados e desabilitar a aprovação até que todos os arquivos tenham sido marcados como visualizados.	Cenário UCA-IP-10
DR-15	Deve ser definido e monitorado um SLA máximo para decisão da InfoPrivSec sobre Pull Requests rotuladas como críticas, com escalonamento automático em caso de descumprimento.	Cenário UCA-IP-11
DR-16	Toda Pull Request com lógica de processamento de dados pessoais com múltiplos caminhos de execução deve listar explicitamente, em sua descrição, todos os fluxos alternativos e condições de exceção como pré-requisito para entrar na fila de revisão da InfoPrivSec.	Cenário UCA-IP-12

Síntese

Os dezesseis requisitos derivados (DR-1 a DR-16) atuam em três frentes complementares: (i) enriquecimento do feedback recebido pela InfoPrivSec, tornando explícitos riscos hoje invisíveis em seu modelo de processo (DR-1, DR-3, DR-9, DR-13); (ii) controles técnicos estruturais que removem a dependência exclusiva do julgamento humano em momentos críticos (DR-2, DR-5, DR-10, DR-14); e (iii) políticas organizacionais e de prazo que eliminam ambiguidades em situações de conflito de objetivos (DR-11, DR-12, DR-15). Em conjunto, esses requisitos buscam fechar as lacunas estruturais identificadas nos doze cenários de perda, sem depender unicamente do aumento de atenção ou diligência individual do revisor.